

C2.3 | Documento de Arquitectura aprobado

SSO

Ministerio de Educación, Deporte y Cultura (MINEDEC)

CNT

MINEDEC

Versión 0.1

2026

Control del documento

Campo	Información
Documento	Documento de Arquitectura de la integración de 2 aplicaciones legadas con el SSO
Código	
Versión	0.1
Fecha	09/10/2026
Responsable	Equipo de Desarrollo

Historial de versiones

Versión	Fecha	Responsable	Descripción del cambio
0.1	09/10/2026	Equipo de Desarrollo	Versión inicial del documento

Identificación del entregable

Campo	Información
ID del entregable	C2-59
Componente	C2
Subcomponente	Integración de 2 aplicaciones legadas del MINEDEC con el sistema de autenticación centralizado SSO
Fase / etapa	Fase de Análisis y Diseño de Arquitectura
Nombre contractual del entregable	Documento de Arquitectura aprobado
Proyecto / iniciativa	Single Sign-On (SSO) e Integración con aplicaciones legadas
Entidad / cliente	Ministerio de Educación, Deporte y Cultura (MINEDEC)
Responsable	Equipo de Desarrollo
Versión	0.1

Contenido

Control del documento 1
Historial de versiones 2
Identificación del entregable 2
Contenido 3
1. Contexto e introducción 4
1.1 Antecedentes y relación con C2.2 5
2. Objetivo 5
3. Alcance 5
3.1 Dentro del alcance 5
3.2 Fuera del alcance 5
3.3 Audiencia 6
4. Insumos, dependencias y fuentes 6
5. Desarrollo específico del entregable 7
5.1 Principios de diseño 7
5.2 Vista de contexto (C4 nivel 1) 7
5.3 Vista de contenedores (C4 nivel 2) 8
5.4 Vista de componentes del módulo de integración (C4 nivel 3) 9
5.5 Protocolos y flujos de autenticación 10
5.5.1 OIDC con Authorization Code y PKCE S256 (principal) 10
5.5.2 SAML 2.0 iniciado por el SP (alternativo) 10
5.5.3 Registro de la aplicación en Google 11
5.6 Consumo del contrato de autorización 11
5.7 Modificaciones en frontend y backend 12
5.8 Almacén de llaves (JKS) y gestión de secretos 12
5.9 Mapeo de atributos y perfiles 13
5.10 Desacople de contraseñas locales 14
5.11 Sesiones y cierre de sesión 14
5.12 Conectividad e infraestructura 15
5.13 Trazabilidad y auditoría 15
6. Validación, criterios de aceptación y evidencias 15
7. Conclusiones 17
8. Recomendaciones y próximos pasos 17
8.1 Decisiones pendientes 17
8.2 Próximos pasos 17
9. Referencias 18
10. Anexos 19
Anexo A. Glosario 19
Anexo B. Riesgos de la integración 20

1. Contexto e introducción

El Ministerio de Educación, Deporte y Cultura (MINEDEC), con la Corporación Nacional de Telecomunicaciones (CNT EP), implementa Conecta MINEDEC, el sistema de autenticación y autorización centralizado (SSO) que usa Google Cloud Identity como proveedor de identidad. El Subcomponente C2.2 construye la plataforma central; el Subcomponente C2.3, objeto de este documento, integra dos aplicaciones legadas del Ministerio con esa plataforma, conforme a los Términos de Referencia [1].

Este documento es el diseño técnico detallado de la integración (SAD con el modelo C4) que el TDR exige para el entregable C2-59: protocolos, conectores y componentes intermedios, flujo de autenticación e identidad, modificaciones de frontend y backend, filtro o librería SP, almacén de llaves (JKS), mapeo de atributos y perfiles, y desacople de contraseñas locales sin alterar la funcionalidad de las aplicaciones [1].

1.1 Antecedentes y relación con C2.2

El parque del Ministerio tiene alrededor de 170 aplicaciones construidas en distintas épocas y tecnologías, la mayoría con tablas locales de usuarios y contraseñas. La arquitectura de Conecta MINEDEC define dos patrones de integración [3]:

- **Patrón 1 · Integración nativa:** la aplicación incorpora una librería estándar OIDC o SAML 2.0 de su stack y consulta la autorización a Conecta MINEDEC. Es el patrón que se aplica a las dos aplicaciones de C2.3.
- **Patrón 2 · Integración perimetral:** un punto de ejecución de políticas (PEP) en Google Cloud protege las aplicaciones sin cambiar su código. Su diseño (alternativas de PEP, red híbrida, publicación desde la consola y contrato de cabeceras X-Minedec-*) es parte de C2.2 y se documenta en el Documento de Arquitectura C2-50 [3].

C2.3 consume de C2.2 el contrato de autorización (/api/v1/oauth/token y /api/v1/authorize), el paquete estándar de integración y la suite de pruebas de conformidad [3]. Por eso este documento no redefine esos elementos: describe cómo los usa cada aplicación.

2. Objetivo

Definir la arquitectura con la que las dos aplicaciones legadas que seleccione el MINEDEC delegan la autenticación en Google Cloud Identity y la autorización en Conecta MINEDEC, retiran el inicio de sesión con contraseñas locales y conservan su funcionalidad, sus datos y su historial.

3. Alcance

3.1 Dentro del alcance

- Diseño de la integración de las dos aplicaciones legadas que formalice el MINEDEC (decisión D-03).
- Modelo C4 de la integración: contexto, contenedores y componentes del módulo de integración.
- Flujos OIDC (Authorization Code con PKCE) y SAML 2.0 iniciado por el SP, y consumo del contrato de autorización de Conecta MINEDEC.
- Modificaciones de frontend y backend, filtro o librería SP, almacén de llaves (JKS) y gestión de secretos.
- Mapeo de atributos y perfiles, vinculación de las cuentas locales por número de identificación y desacople de las contraseñas locales.
- Requisitos de conectividad e infraestructura de cada aplicación hacia Conecta MINEDEC y criterios de validación de la integración.

3.2 Fuera del alcance

- La plataforma central Conecta MINEDEC (motor de autorización, consola de administración, sincronizador, auditoría e infraestructura base), que es parte de C2.2 [3].
- El patrón perimetral para el resto del parque, las alternativas de PEP, la red híbrida y la publicación automatizada de aplicaciones, documentados en C2-50 [3].
- El aprovisionamiento de cuentas en Google Workspace, a cargo de C1.4 y de los administradores del MINEDEC.
- Cambios funcionales en las aplicaciones legadas distintos de los necesarios para la autenticación y la autorización.

3.3 Audiencia

Arquitectos y desarrolladores de CNT y de los equipos dueños de las dos aplicaciones, administradores de Google Workspace y de Seguridad Informática del MINEDEC, y el administrador del contrato.

4. Insumos, dependencias y fuentes

La Tabla 1 resume los insumos del cliente, las dependencias con otros entregables y las fuentes de este documento.

Tabla 1. Insumos, dependencias y fuentes de C2-59

Tipo	Elemento	Procedencia / responsable	Observación
Insumo del cliente	Selección formal de las dos aplicaciones legadas (D-03)	MINEDEC – Desarrollo de Proyectos de TI	Pendiente. Bloquea el diseño específico de cada aplicación.
Insumo del cliente	Ficha técnica de cada aplicación: stack, autenticación actual, URL y ambientes, responsable técnico y número de usuarios	MINEDEC – áreas dueñas	Pendiente. Define la librería SP y las modificaciones.
Insumo del cliente	Acceso al código fuente, la documentación y las credenciales de ambientes de las dos aplicaciones	MINEDEC – áreas dueñas	Pendiente.
Insumo del cliente	Cuentas de prueba en Cloud Identity por tipo de usuario, en una unidad organizativa aislada (D-15)	MINEDEC – Administrador de Workspace	Pendiente. Necesarias para probar OIDC, SAML y el segundo factor.
Insumo del cliente	Registro de las aplicaciones en Google: app SAML personalizada y habilitación para las unidades organizativas del piloto	MINEDEC – Superadministrador de Workspace	Se hace desde la consola de administración; Google no ofrece API para esta configuración [3].
Insumo del cliente	Ubicación de las aplicaciones y conectividad híbrida (D-17)	MINEDEC – Infraestructura	Pendiente. El motor de autorización solo es accesible por red privada.
Insumo del cliente	Dominios de docentes y administrativos y tenants de Workspace (D-21)	MINEDEC – Coordinación General de TIC	Pendiente. Estudiantes: estudiante.edu.ec [1].
Dependencia interna	C2-50 Documento de Arquitectura de C2.2: contrato de autorización, paquete estándar y pruebas de conformidad	CNT – equipo C2	El contrato canónico se publica en OpenAPI.
Dependencia interna	C2-58 Documento de Análisis Funcional de C2.3	CNT – equipo C2	Define los flujos de uso, las reglas de negocio y los roles de cada aplicación.

Fuente / referencia	Términos de Referencia, Componente C2, Subcomponente 3	MINEDEC	Documento rector [1].
Fuente / referencia	Documento de Requerimientos de Conecta MINEDEC	CNT	Versión 0.4: requerimientos RF-INT y decisiones D-xx [2].

Fuente: elaboración propia.

5. Desarrollo específico del entregable

El capítulo sigue la estructura sugerida para documentos de arquitectura: principios, vistas del modelo C4 [12], flujos, decisiones de diseño por tema y requisitos de infraestructura. Mientras el MINEDEC no formalice las dos aplicaciones (D-03), el diseño se expresa de forma genérica por stack; al recibir las fichas técnicas se completa la Tabla 6 y los campos marcados como «Por definir (TBD)».

5.1 Principios de diseño

- **Estándares, sin desarrollos a medida por lenguaje:** cada aplicación usa una librería OIDC o SAML 2.0 madura de su propio stack, configurada con los perfiles del paquete estándar de C2.2 [3].
- **OIDC como protocolo principal:** SAML 2.0 se usa solo cuando el stack o el producto no admite OIDC de forma confiable [2].
- **Autorización centralizada:** la aplicación no decide sola quién entra; consulta a Conecta MINEDEC (/api/v1/authorize) y aplica la decisión, en línea con el modelo de confianza cero [13].
- **Cierre ante fallas (fail-close):** si Conecta MINEDEC no responde o devuelve error, la aplicación deniega el acceso; nunca lo concede por defecto.
- **Cero secretos en código:** las credenciales, llaves y certificados se guardan en Google Cloud Secret Manager y se entregan a la aplicación en el despliegue o el arranque [11].
- **Mínima intervención:** solo cambian el inicio y el cierre de sesión, el control de acceso y la vinculación de cuentas; la lógica de negocio y los datos no cambian.
- **Reversibilidad controlada:** el inicio de sesión local se deshabilita con una bandera de configuración que solo se reactiva con el plan de reversa del Documento de Puesta en Producción (C2-62).

5.2 Vista de contexto (C4 nivel 1)

La Figura 1 muestra cada aplicación piloto en su entorno: quién la usa y con qué sistemas se relaciona. La Tabla 2 describe cada elemento.

Figura 1. Vista de contexto de la integración de una aplicación piloto

Por definir (TBD): diagrama C4 de contexto; la fuente editable se mantiene en draw.io.

Tabla 2. Elementos de la vista de contexto

Elemento	Tipo	Responsabilidad en la integración
Usuario institucional (administrativo, docente o estudiante)	Persona	Inicia sesión con su cuenta de Google Workspace y con el segundo factor (2SV) cuando su unidad organizativa lo exige.

Aplicación legada piloto	Sistema en alcance	Delega la autenticación, consulta la autorización y aplica la decisión; conserva su lógica y sus datos.
Google Cloud Identity	Sistema externo (IdP)	Autentica al usuario y emite el ID Token OIDC o la aserción SAML 2.0 firmados.
Conecta MINEDEC (C2.2)	Sistema de la plataforma	Emite el token de cliente de la aplicación y decide el acceso con roles, atributos y ámbito territorial.
Google Cloud Secret Manager	Servicio de soporte	Custodia el secreto del cliente, las llaves y los certificados de la integración.

Fuente: elaboración propia.

5.3 Vista de contenedores (C4 nivel 2)

La Figura 2 y la Tabla 3 detallan los contenedores que intervienen. El módulo de integración se ejecuta dentro del backend de la aplicación; no se agrega un servidor intermedio.

Figura 2. Vista de contenedores de la integración

Por definir (TBD): diagrama C4 de contenedores; la fuente editable se mantiene en draw.io.

Tabla 3. Elementos de la vista de contenedores

Contenedor	Tecnología	Responsabilidad	Comunicación
Frontend de la aplicación	La del stack de la aplicación (TBD, D-03)	Muestra «Ingresar con Conecta MINEDEC», el usuario autenticado y el cierre de sesión.	HTTPS con el navegador
Backend con el módulo de integración	La del stack, con una librería OIDC o SAML estándar	Procesa el retorno del IdP, crea la sesión local, consulta la autorización y protege las rutas.	HTTPS hacia Google y hacia Conecta MINEDEC
Base de datos local	La existente de la aplicación	Conserva usuarios, roles locales e historial; deja de guardar contraseñas utilizables.	Sin cambios de motor
Endpoints de Google (OIDC y SAML)	accounts.google.com y oauth2.googleapis.com	Autorización, emisión de tokens, llaves públicas (JWKS) y respuesta SAML.	HTTPS público
API de Conecta MINEDEC	/api/v1/oauth/token y /api/v1/authorize detrás de un balanceador interno	Token de cliente (1 hora) y decisión de autorización.	HTTPS por red privada (D-17)
Secret Manager	Servicio gestionado de Google Cloud	Secreto del cliente OIDC, llaves y certificados SAML y contraseñas del almacén JKS.	Lectura en el despliegue o el arranque

Fuente: elaboración propia.

5.4 Vista de componentes del módulo de integración (C4 nivel 3)

El módulo de integración es la pieza que el TDR denomina filtro o librería SP. Se arma con componentes de la librería estándar del stack y una capa delgada propia que consulta a Conecta MINEDEC, como muestran la Figura 3 y la Tabla 4.

Figura 3. Componentes del módulo de integración

Por definir (TBD): diagrama C4 de componentes; la fuente editable se mantiene en draw.io.

Tabla 4. Componentes del módulo de integración

Componente	Responsabilidad	Origen
Filtro de autenticación	Intercepta las rutas protegidas y redirige al IdP cuando no hay una sesión válida.	Librería estándar (filtro o middleware del framework)
Cliente OIDC o SAML	Arma la solicitud (PKCE o AuthnRequest), procesa el retorno y valida firma, emisor, audiencia y vigencia.	Librería estándar del stack
Gestor de sesión local	Crea, renueva e invalida la sesión de la aplicación y su cookie segura.	Mecanismo de sesión existente de la aplicación
Cliente de autorización	Obtiene el token de cliente, consulta /api/v1/authorize, guarda la decisión hasta 300 s y aplica el cierre ante fallas.	Capa propia mínima, según el perfil del paquete estándar
Mapeador de atributos y roles	Traduce los roles y atributos de Conecta MINEDEC a los roles y permisos locales.	Configuración por aplicación (Tabla 11)
Vinculador de cuenta local	Asocia la identidad verificada con el registro local por número de identificación.	Capa propia mínima
Proveedor de secretos	Carga llaves, certificados y secretos desde Secret Manager o desde el almacén JKS generado en el despliegue.	Cliente de Secret Manager o pipeline de despliegue
Registro de auditoría	Registra inicios y cierres de sesión, decisiones y errores con un identificador de correlación.	Logger existente de la aplicación

Fuente: elaboración propia.

La Tabla 5 propone librerías de referencia por stack; la definitiva se confirma con la ficha técnica de cada aplicación. La Tabla 6 es la ficha de integración que se completa por aplicación.

Tabla 5. Librerías estándar de referencia por stack

Stack	OIDC	SAML 2.0
Java con Spring	Spring Security OAuth2 Login	Spring Security SAML2 Service Provider
Java EE sin Spring	pac4j (filtro de servlet)	pac4j (filtro de servlet)
.NET (ASP.NET Core)	Microsoft.AspNetCore.Authentication.OpenIdConnect	Sustainsys.Saml2
PHP	Librería OIDC certificada por la OpenID Foundation para PHP (TBD)	OneLogin php-saml

Python	Authlib	OneLogin python3-saml
Node.js	openid-client	@node-saml/passport-saml

Fuente: elaboración propia.

Tabla 6. Ficha de integración por aplicación

Campo	Aplicación 1	Aplicación 2
Nombre y área dueña	Por definir (TBD, D-03)	Por definir (TBD, D-03)
Stack (lenguaje, framework y servidor)	Por definir (TBD)	Por definir (TBD)
Protocolo	OIDC (principal) o SAML 2.0	OIDC (principal) o SAML 2.0
Librería SP	Por definir (TBD)	Por definir (TBD)
Ubicación y ambientes	Por definir (TBD, D-17)	Por definir (TBD, D-17)
Tipos de usuario y número de usuarios	Por definir (TBD)	Por definir (TBD)

Fuente: elaboración propia.

5.5 Protocolos y flujos de autenticación

Cada aplicación implementa uno de los dos flujos. La elección se registra en la Tabla 6 al recibir la ficha técnica.

5.5.1 OIDC con Authorization Code y PKCE S256 (principal)

1. El usuario abre una ruta protegida; el filtro detecta que no hay sesión y genera state, nonce y el par code_verifier / code_challenge (SHA-256) [8].
2. El navegador se redirige al endpoint de autorización de Google con el client_id de la aplicación, el alcance «openid email profile» y el redirect_uri registrado [4].
3. Google autentica al usuario con su cuenta institucional y, si su unidad organizativa lo exige, con el segundo factor.
4. Google devuelve el código de autorización al redirect_uri. El backend lo canjea por el ID Token en el endpoint de tokens, de servidor a servidor, con el code_verifier y el secreto del cliente.
5. El backend valida la firma RS256 del ID Token con las llaves públicas de Google (JWKS), el emisor, la audiencia, el nonce, la vigencia y que el correo esté verificado [7].
6. El backend consulta /api/v1/authorize con el correo autenticado (sección 5.6). Si la decisión es favorable, vincula la cuenta local (sección 5.10), crea la sesión y redirige a la página solicitada.

Nota: el ID Token de Google solo trae claims estándar (sub, email, email_verified, name, given_name, family_name y hd). Los atributos del esquema MINEDEC_Perfil no viajan en el token OIDC y se obtienen de la respuesta de /api/v1/authorize [4].

5.5.2 SAML 2.0 iniciado por el SP (alternativo)

1. El usuario abre una ruta protegida; el filtro genera una AuthnRequest con identificador único y la envía al servicio de inicio de sesión de Google con el binding que admita la librería (HTTP-Redirect o HTTP-POST) [9].

2. Google autentica al usuario y envía la respuesta SAML firmada al Assertion Consumer Service (ACS) de la aplicación.
3. El backend valida la firma con el certificado del IdP guardado en el almacén de confianza, el destinatario, la audiencia (Entity ID), la vigencia y que la respuesta corresponda a la solicitud (InResponseTo).
4. El backend toma el NameID (correo institucional) y los atributos mapeados en la app SAML personalizada, y consulta /api/v1/authorize como en el flujo OIDC.

Nota: la app SAML personalizada de Google permite mapear atributos del perfil del usuario, incluidos los del esquema personalizado, a atributos de la aserción [5]. Aun así, la decisión de acceso y los roles salen siempre de Conecta MINEDEC.

5.5.3 Registro de la aplicación en Google

El cliente OAuth (OIDC) lo crea CNT en el proyecto de Google Cloud de la integración. La app SAML personalizada la crea el superadministrador de Google Workspace del MINEDEC en la consola de administración y la habilita para las unidades organizativas de los usuarios del piloto [5]. Las dos configuraciones se hacen desde la consola porque Google no ofrece una API para crearlas [3]; CNT entrega una ficha con los valores (redirect_uri, ACS, Entity ID y atributos) y el responsable se define en D-19.

5.6 Consumo del contrato de autorización

La aplicación se autentica ante Conecta MINEDEC con OAuth 2.0 client credentials [10] y luego consulta la decisión. Los dos endpoints, sus campos y el catálogo de respuestas son los definidos en C2-50 [3]; la Tabla 7 resume cómo los usa la aplicación.

Tabla 7. Uso del contrato de autorización por la aplicación

Paso	Endpoint	Datos que envía	Uso de la respuesta
1. Token de cliente	POST /api/v1/oauth/token	client_id y client_secret de la aplicación (en Secret Manager).	Token de 1 hora; se renueva antes de vencer y nunca se registra en logs.
2. Decisión	POST /api/v1/authorize	email_autenticado, host_solicitado, ruta_solicitada, metodo_http y atributos_contexto (IP de origen y user agent).	autorizado y codigo_decision definen el acceso; numero_identificacion y tipo_identificacion vinculan la cuenta; roles y contexto_territorial alimentan el mapeo.
3. Caché	—	—	La decisión se guarda en la sesión hasta cache_ttl_segundos (máximo 300 s); al vencer se vuelve a consultar.

Fuente: elaboración propia.

Cierre ante fallas. Si /api/v1/authorize no responde dentro del tiempo de espera configurado, devuelve un error 5xx o el token de cliente no puede renovarse, la aplicación deniega el acceso y muestra una página de servicio no disponible. Una decisión negativa (autorizado = false) se muestra como acceso denegado, sin revelar detalles de la política.

Granularidad. La consulta se hace al iniciar la sesión y al vencer el TTL. Las aplicaciones que necesiten control por ruta consultan también al entrar a cada módulo protegido, con la misma caché.

5.7 Modificaciones en frontend y backend

La Tabla 8 lista las modificaciones mínimas. Ninguna altera reglas de negocio, reportes ni datos funcionales de la aplicación.

Tabla 8. Modificaciones mínimas en la aplicación

Capa	Modificación	Detalle
Frontend	Pantalla de inicio de sesión	Se reemplaza el formulario de usuario y contraseña por el botón «Ingresar con Conecta MINEDEC».
Frontend	Recuperación y cambio de contraseña	Se retiran; la contraseña se gestiona en Google Workspace.
Frontend	Cierre de sesión	Invoca el cierre local y redirige a la página institucional de salida (sección 5.11).
Frontend	Mensajes de error	Páginas de acceso denegado y de servicio no disponible.
Backend	Filtro de autenticación	Protege todas las rutas salvo las públicas declaradas (recursos estáticos, salud y retorno del IdP).
Backend	Retorno del IdP	Endpoint redirect_uri (OIDC) o Assertion Consumer Service (SAML).
Backend	Cliente de autorización	Token de cliente, consulta a /api/v1/authorize, caché de hasta 300 s y cierre ante fallas.
Backend	Vinculación y roles	Busca al usuario local por número de identificación y aplica el mapeo de roles.
Backend	Configuración	Parámetros externos por ambiente: client_id, URL del IdP y de Conecta MINEDEC, Entity ID, rutas públicas y bandera LOCAL_LOGIN_ENABLED.
Base de datos	Identificación del usuario	Si no existe, se agrega el número y el tipo de identificación; las contraseñas locales quedan inutilizables (sección 5.10).

Fuente: elaboración propia.

5.8 Almacén de llaves (JKS) y gestión de secretos

La Tabla 9 identifica el material criptográfico de la integración. Secret Manager es la fuente única [11]; en las aplicaciones Java, el pipeline de despliegue genera el almacén JKS (o PKCS#12) a partir de Secret Manager, como pide el TDR [1][6]. En otros stacks, el material se carga en memoria desde Secret Manager o desde archivos montados en el despliegue.

Tabla 9. Material criptográfico de la integración

Material	Protocolo	Contenido	Custodia y rotación
Secreto del cliente OAuth	OIDC	client_secret del cliente registrado en Google.	Secret Manager; rotación con un segundo secreto vigente

			durante el cambio.
Credencial de cliente de Conecta MINEDEC	OIDC y SAML	client_id y client_secret para /api/v1/oauth/token.	Secret Manager; se rota desde la consola de Conecta MINEDEC (C2.2).
Certificado del IdP de Google	SAML	Certificado X.509 con el que se valida la firma de la respuesta.	Almacén de confianza (truststore JKS) generado desde Secret Manager; se renueva antes de su vencimiento.
Par de llaves del SP	SAML	Llave privada y certificado del SP, si la aplicación firma solicitudes o recibe aserciones cifradas.	Almacén JKS o PKCS#12 generado desde Secret Manager; nunca en el repositorio.
Contraseñas de los almacenes	SAML (Java)	Contraseña del keystore y de la llave privada.	Secret Manager; se inyectan como variables de entorno o archivos en el despliegue.

Fuente: elaboración propia.

- Ningún secreto, llave o almacén JKS se guarda en el repositorio de código ni en archivos de configuración versionados.
- Si la aplicación corre en Google Cloud, lee Secret Manager con una cuenta de servicio dedicada y sin llaves JSON (Workload Identity en GKE o identidad nativa del servicio). Si corre en los centros de datos del MINEDEC, el pipeline de despliegue entrega el material; el mecanismo se define con la ficha técnica (TBD, D-03).
- Las lecturas y rotaciones de secretos quedan en Cloud Audit Logs, con los registros de acceso a datos de Secret Manager habilitados.

5.9 Mapeo de atributos y perfiles

La Tabla 10 indica de dónde obtiene la aplicación cada dato de identidad y en qué campo local lo guarda. La Tabla 11 es la plantilla del mapeo de roles, que se completa con el análisis funcional de cada aplicación (C2-58).

Tabla 10. Origen y destino de los atributos de identidad

Dato	Origen	Campo local	Uso
Correo institucional	Claim email (OIDC) o NameID (SAML)	Usuario o correo	Identidad autenticada; se envía a /api/v1/authorize.
Nombres y apellidos	given_name y family_name (OIDC) o atributos mapeados (SAML)	Nombres del usuario	Presentación; se actualizan en cada inicio de sesión.
Número y tipo de identificación	numero_identificacion y tipo_identificacion de /api/v1/authorize	Identificación del usuario	Vinculación con el registro local (sección 5.10).
Roles	roles de /api/v1/authorize	Roles locales (Tabla 11)	Permisos dentro de la aplicación.
Ámbito territorial	contexto_territorial de /api/v1/authorize (AMIE, zona, distrito y nivel de jurisdicción)	Filtros de datos de la aplicación	Restricción de los datos por institución o territorio.

Fuente: elaboración propia.

Tabla 11. Plantilla de mapeo de roles por aplicación

Rol en Conecta MINEDEC	Rol o perfil local	Alcance de datos	Observación
Por definir (TBD, C2-58)	Por definir (TBD)	Por definir (TBD)	Se completa con el inventario de roles de cada aplicación (D-12).

Fuente: elaboración propia.

Los roles se administran en la consola de Conecta MINEDEC por el administrador de la aplicación; la aplicación no los edita localmente. Si un rol de Conecta MINEDEC no tiene equivalente local, el acceso se deniega y se registra el evento.

5.10 Desacople de contraseñas locales

El objetivo es retirar las contraseñas locales sin perder usuarios, roles ni historial. El procedimiento por aplicación es:

1. **Vinculación previa:** se carga en la tabla local de usuarios el número y el tipo de identificación de cada usuario activo, a partir de la copia de identidades de Conecta MINEDEC; los registros sin coincidencia se reportan al área dueña.
2. **Convivencia controlada:** en el ambiente de pruebas se habilita el ingreso por Conecta MINEDEC con LOCAL_LOGIN_ENABLED en verdadero, para comparar resultados.
3. **Corte:** en producción, LOCAL_LOGIN_ENABLED pasa a falso; el formulario local desaparece y el backend rechaza cualquier intento de autenticación con contraseña.
4. **Inutilización de contraseñas:** el hash de contraseña de cada usuario se reemplaza por un valor aleatorio no utilizable; el registro, sus llaves foráneas y el historial de auditoría se conservan.
5. **Usuarios nuevos:** si el usuario autorizado no existe localmente, se crea en el primer ingreso (aprovisionamiento justo a tiempo) solo si la regla de negocio de la aplicación lo permite; si no, se deniega el acceso y se notifica al área dueña.

La reactivación del inicio de sesión local solo procede mediante el plan de reversa del Documento de Puesta en Producción de C2.3 (C2-62), con el cambio aprobado.

5.11 Sesiones y cierre de sesión

- La sesión local dura lo que defina la aplicación, pero la decisión de autorización se revalida al vencer su TTL (máximo 300 s) [3].
- Google no implementa el cierre de sesión único (SLO) remoto para OIDC ni procesa LogoutRequest de SAML; el cierre es local y la revocación se hace efectiva por revalidación [3].
- Si el administrador suspende la cuenta en Workspace o retira un rol en Conecta MINEDEC, la aplicación deja de permitir el acceso a más tardar al vencer el TTL de la decisión.
- Las aplicaciones en las que aplica el cierre de sesión coordinado se confirman en la decisión D-11.

5.12 Conectividad e infraestructura

El endpoint /api/v1/authorize de Conecta MINEDEC solo se publica en red privada, nunca en Internet [3]. Por eso cada aplicación necesita una ruta privada hasta el balanceador interno de Conecta MINEDEC, que depende de dónde se ejecute (ver la Tabla 12).

Tabla 12. Requisitos de infraestructura según la ubicación de la aplicación

Ubicación de la aplicación	Conectividad hacia Conecta MINEDEC	Acceso a secretos	Dependencia
Centro de datos del MINEDEC	Conectividad híbrida (HA VPN o Cloud Interconnect) hasta la VPC de Conecta MINEDEC.	Entrega en el despliegue mediante el pipeline.	D-17
Google Cloud (GKE o Cloud Run)	Red de la VPC de Conecta MINEDEC o interconexión con ella.	Cuenta de servicio dedicada con roles/secretmanager.secret Accessor sobre sus secretos, sin llaves JSON.	D-03
Otra nube o proveedor	Por definir (TBD)	Por definir (TBD)	D-03 y D-17

Fuente: elaboración propia.

Los recursos de Google Cloud propios de C2.3 se limitan al cliente OAuth, a los secretos de cada aplicación y, si la aplicación corre en Google Cloud, a su cuenta de servicio. La red, los balanceadores y la conectividad híbrida son parte de la infraestructura de C2.2 [3]. Todo recurso nuevo se declara en Terraform y se entrega con el acta de código fuente e IaC (C2-65).

5.13 Trazabilidad y auditoría

- La aplicación registra el inicio y el cierre de sesión, la decisión recibida (código y política, sin datos sensibles), los errores de validación y las denegaciones por cierre ante fallas.
- Cada solicitud a Conecta MINEDEC propaga la cabecera W3C traceparent, para correlacionar el evento con el registro de auditoría de la plataforma.
- No se registran tokens, secretos, contraseñas ni aserciones completas, en cumplimiento de la LOPDP [15] y de las buenas prácticas de OWASP ASVS [14].
- Conecta MINEDEC conserva su propia bitácora inmutable de decisiones (C2.2), por lo que la aplicación no necesita replicarla.

6. Validación, criterios de aceptación y evidencias

La Tabla 13 verifica que el documento cubre lo que exige el TDR para el Documento de Arquitectura de C2.3. La Tabla 14 lista las pruebas con las que se validará la integración en el Documento de Aceptación Funcional (C2-60), basadas en la suite de conformidad de C2.2 [3].

Tabla 13. Criterios de aceptación del documento

N.º	Criterio (TDR)	Evidencia	Estado / observación
1	Diseño técnico con el modelo C4 de la integración	Secciones 5.2 a 5.4 y Figuras 1 a 3	Pendiente: insertar las figuras.
2	Protocolos SAML 2.0 y OpenID Connect / OAuth 2.0	Secciones 5.5 y 5.6	Cumple.

3	Conectores y componentes intermedios	Secciones 5.3, 5.4 y 5.12	Cumple.
4	Flujo de autenticación e identidad	Sección 5.5	Cumple.
5	Modificación de frontend y backend	Sección 5.7	Cumple en forma genérica; se detalla por aplicación con D-03.
6	Filtro o librería SP	Sección 5.4, Tabla 5 y Tabla 6	Pendiente: stack de cada aplicación (D-03).
7	Almacén de llaves (JKS)	Sección 5.8	Cumple.
8	Mapeo de atributos y perfiles	Sección 5.9	Parcial: el mapeo de roles por aplicación depende de C2-58.
9	Desacople de contraseñas sin alterar la funcionalidad	Secciones 5.7 y 5.10	Cumple.

Fuente: elaboración propia.

Tabla 14. Pruebas de validación de la integración

N.º	Prueba	Resultado esperado
PI-01	Inicio de sesión OIDC con PKCE y segundo factor	Sesión creada solo con un ID Token válido; los tokens alterados, vencidos o de otra audiencia se rechazan.
PI-02	Inicio de sesión SAML 2.0 iniciado por el SP (si la aplicación usa SAML)	Se acepta una respuesta con firma válida; se rechazan la firma inválida, el destinatario incorrecto y la respuesta repetida.
PI-03	Autorización permitida y denegada	El usuario con rol entra con sus permisos locales; el usuario sin rol recibe acceso denegado.
PI-04	Cierre ante fallas	Con Conecta MINEDEC no disponible, la aplicación deniega el acceso.
PI-05	Inicio de sesión local deshabilitado	No existe formulario local y el backend rechaza las credenciales locales.
PI-06	Vinculación e historial	El usuario vinculado por número de identificación conserva sus datos y su historial.
PI-07	Revocación	Tras la suspensión en Workspace o el retiro del rol, el acceso se deniega a más tardar en 300 s.
PI-08	Rotación de secretos y llaves	El cambio de secreto o de certificado no interrumpe el servicio.

Fuente: elaboración propia.

El rendimiento de los puntos de integración se mide en el Documento de Pruebas de Carga y Stress (C2-61), con los niveles de servicio que defina el MINEDEC (D-06).

7. Conclusiones

- La integración de las dos aplicaciones usa el patrón nativo con librerías estándar de cada stack, sin componentes intermedios propios, lo que reduce el mantenimiento y permite replicarla en otras aplicaciones.
- La autorización queda centralizada en Conecta MINEDEC con cierre ante fallas: las altas, bajas y cambios de rol se reflejan en las aplicaciones sin intervenir su código.
- El desacople de contraseñas conserva usuarios, roles e historial, y solo se revierte con el procedimiento de cambio aprobado.
- El detalle de cada aplicación (stack, librería, mapeo de roles y ubicación) depende de que el MINEDEC formalice las dos aplicaciones (D-03).

8. Recomendaciones y próximos pasos

8.1 Decisiones pendientes

La Tabla 15 resume las decisiones del MINEDEC que condicionan este diseño [2].

Tabla 15. Decisiones pendientes que condicionan C2.3

Código	Decisión	Impacto en C2.3	¿Bloquea?
D-03	Selección formal de las dos aplicaciones legadas	Define el stack, la librería SP, las modificaciones y el mapeo de roles.	Sí: todo C2.3
D-15	Cuentas de prueba en Cloud Identity por tipo de usuario	Sin ellas no se prueban OIDC, SAML ni el segundo factor.	Sí: las pruebas
D-17	Ubicación de las aplicaciones y conectividad híbrida	Habilita la ruta privada hacia /api/v1/authorize.	Sí: aplicaciones en los centros de datos del MINEDEC
D-21	Dominios y tenants de Google Workspace	Define los dominios aceptados y el registro del cliente OAuth y de la app SAML.	Sí: la configuración de la federación
D-12	Inventario de roles, perfiles y atributos por aplicación	Completa el mapeo de roles.	No el inicio; sí el mapeo
D-11	Aplicaciones con cierre de sesión coordinado	Alcance del cierre de sesión.	No
D-06	Niveles de servicio y concurrencia pico	Escenarios de las pruebas de carga (C2-61).	No el diseño; sí las pruebas

Fuente: elaboración propia.

8.2 Próximos pasos

1. Formalizar las dos aplicaciones (D-03) y recibir sus fichas técnicas y el acceso al código.
2. Completar la Tabla 6 y la Tabla 11 con el stack, la librería SP, el protocolo, la ubicación y el mapeo de roles de cada aplicación.
3. Insertar las Figuras 1 a 3 del modelo C4 con los datos de cada aplicación.
4. Registrar el cliente OAuth o la app SAML con el superadministrador de Workspace y cargar los secretos en Secret Manager.

5. Ejecutar las pruebas de la Tabla 14 en el ambiente de pruebas y documentarlas en C2-60.

9. Referencias

Tabla 16. Referencias

N.º	Autor / entidad	Documento o recurso	Versión / enlace
[1]	MINEDEC	Términos de Referencia, Componente C2, Subcomponente 3: Integración de 2 aplicaciones legadas del MINEDEC con el sistema de autenticación centralizado SSO	Versión 01, diciembre de 2025
[2]	CNT	Documento de Requerimientos de Conecta MINEDEC	Versión 0.4. https://docs.google.com/document/d/1MzWrDtiKnlwHe_f4h-Tnwyii7AxhHdz5cWFyszZaGO0
[3]	CNT	C2-50 Documento de Arquitectura aprobado (C2.2)	https://docs.google.com/document/d/1JOiKS4c1ZJlUOa21-dKMgv_YPqiEGKAZNMuy39xigP8
[4]	Google	OpenID Connect	https://developers.google.com/identity/openid-connect/openid-connect
[5]	Google	Configurar una app SAML personalizada	https://support.google.com/a/answer/6087519
[6]	Oracle	keytool (JDK 21)	https://docs.oracle.com/en/java/javase/21/docs/specs/man/keytool.html
[7]	OpenID Foundation	OpenID Connect Core 1.0	https://openid.net/specs/openid-connect-core-1_0.html
[8]	IETF	RFC 7636: Proof Key for Code Exchange by OAuth Public Clients	https://www.rfc-editor.org/rfc/rfc7636
[9]	OASIS	Security Assertion Markup Language (SAML) 2.0	https://docs.oasis-open.org/security/saml/v2.0/
[10]	IETF	RFC 6749: The OAuth 2.0 Authorization Framework	https://www.rfc-editor.org/rfc/rfc6749
[11]	Google Cloud	Documentación de Secret Manager	https://cloud.google.com/secret-manager/docs
[12]	Simon Brown	The C4 model for visualising software architecture	https://c4model.com/
[13]	NIST	SP 800-207: Zero Trust Architecture	https://csrc.nist.gov/pubs/sp/800/207/final
[14]	OWASP	Application Security Verification Standard (ASVS)	https://owasp.org/www-project-application-security-verification-standard/
[15]	Asamblea Nacional del	Ley Orgánica de Protección de Datos Personales	Registro Oficial Suplemento 459, 26 de mayo de 2021

	Ecuador		

Fuente: elaboración propia.

10. Anexos

Anexo A. Glosario

Tabla 17. Glosario de términos

Término	Definición
ACS	Assertion Consumer Service: endpoint de la aplicación que recibe la respuesta SAML.
AuthnRequest	Solicitud de autenticación SAML que la aplicación envía al IdP.
C4	Modelo de documentación de arquitectura en niveles: contexto, contenedores, componentes y código.
Cierre ante fallas (fail-close)	Regla por la que, ante una falla del autorizador, se deniega el acceso.
Entity ID	Identificador único de un proveedor SAML (IdP o SP).
ID Token	Token JWT firmado por el IdP con la identidad autenticada (OIDC).
IdP	Proveedor de identidad; en esta solución, Google Cloud Identity.
JKS	Java KeyStore: archivo que guarda llaves privadas y certificados en aplicaciones Java.
JWKS	Conjunto de llaves públicas que el IdP publica para validar la firma de sus tokens.
NameID	Identificador del usuario en la aserción SAML; aquí, el correo institucional.
OIDC	OpenID Connect: capa de identidad sobre OAuth 2.0.
PDP	Punto de decisión de políticas: el motor de autorización de Conecta MINEDEC.
PEP	Punto de ejecución de políticas: componente que aplica la decisión del PDP.
PKCE	Proof Key for Code Exchange: protección del código de autorización (RFC 7636).
SP	Proveedor de servicio: la aplicación que confía en el IdP.
TTL	Tiempo de vida de un dato en caché antes de volver a consultarlo.
2SV	Verificación en dos pasos de Google (segundo factor).

Fuente: elaboración propia.

Anexo B. Riesgos de la integración

Tabla 18. Riesgos técnicos de la integración y mitigaciones

ID	Riesgo	Probabilidad / impacto	Mitigación
R-01	Retraso en la formalización de las aplicaciones (D-03).	Alta / Alto	Diseño genérico por stack, fechas tentativas en el cronograma y escalamiento al administrador del contrato.
R-02	El stack de la aplicación no tiene una librería OIDC o SAML compatible o mantenida.	Media / Alto	Usar pac4j o el soporte del servidor de aplicaciones; en último caso, evaluar el patrón perimetral de C2.2.
R-03	Usuarios locales sin número de identificación.	Media / Medio	Vinculación previa con reporte de no coincidencias al área dueña antes del corte.
R-04	Falta de conectividad privada hacia Conecta MINEDEC (D-17).	Media / Crítico	Gestionar D-17 desde el inicio; sin ruta privada no se pasa a producción.
R-05	Vencimiento de certificados o secretos.	Baja / Alto	Rotación con material dual y alertas antes del vencimiento.
R-06	Dependencias de seguridad desactualizadas en la aplicación legada.	Media / Medio	Escaneo de dependencias en el pipeline y actualización acotada a las librerías de la integración.

Fuente: elaboración propia.